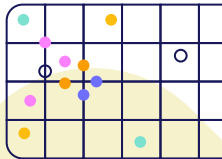
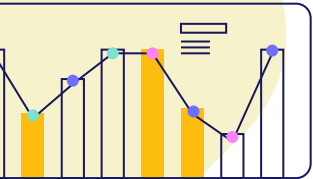


Master 2 Cybersécurité Projet VET

SOC AI Orange

Masha Mirza Zad Ziabary | Abdullah Ahmed-Bark
Swailem | Mirwis Satarzai | Damien Maris



Focus on the Problem :

How can a SOC assistant help distinguish between truly critical vulnerabilities and theoretical vulnerabilities ?



Summary

01.

Co-Teaming Human-AI framework

Collaborate with an AI as if it were a teammate

02.

Human-AI Collaboration in Security Operations Centers with Trusted Autonomy

CyberAlly Case Study

03.

EPSS v3 : Predict Real-World Exploits

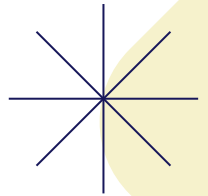
CVE / CVSS / EPSS



04.

Vulnerability Management Chaining

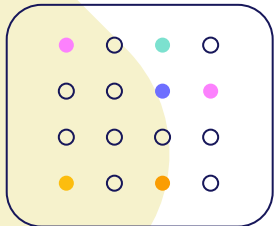
Enhancing Cybersecurity Risk Prioritization



01.

Co-Teaming Human-AI framework

Collaborate with an AI as if it
were a teammate



Towards AI-Driven Human-Machine Co-Teaming for Adaptive and Agile Cyber Security Operation Centers

Massimiliano Albanese

George Mason University FairfaxVA USA
malbanes@gmu.edu

Xinming Ou

University of South Florida TampaFL USA
xou@usf.edu

Kevin Lybarger

George Mason University FairfaxVA USA
klybarg@gmu.edu

Daniel Lende

University of South Florida TampaFL USA
dlende@usf.edu

Dmitry Goldgof

University of South Florida TampaFL USA
goldgof@usf.edu

Context reminder in SOC

- SOC handles an overwhelming number of alerts every day
- Most are false positives or theoretical threats, wasting analyst time
- Analysts need help to focus on truly critical, actionable vulnerabilities

From automation to cooperation: Human-AI Co-Teaming

- AI acts as an apprentice, learning from human analysts
- Humans contribute contextual, tacit knowledge and judgement
- AI handles volume and speed
- Continuous feedback → mutual learning and trust.

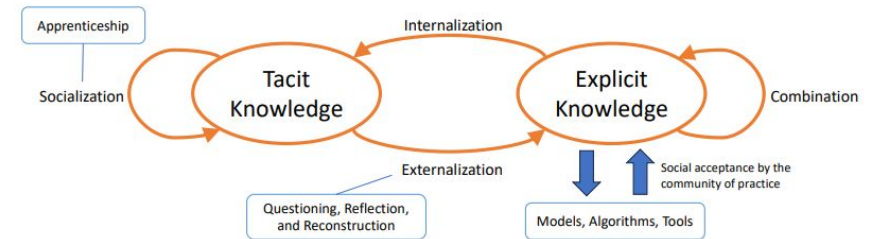


Fig. 1. SECI model for anthropology-guided SOC tool building.

Réf : [1]

Overview of the LLM-Driven Co-Teaming Framework for SOC

Ensure data reliability and consistency
Clean, Normalize

Ensure transparency and evaluation
Report, assessment, execute

Understand organizational context
Connection

Generate, justify, and refine actions
Co-investigation, tacit

Réf : [1]

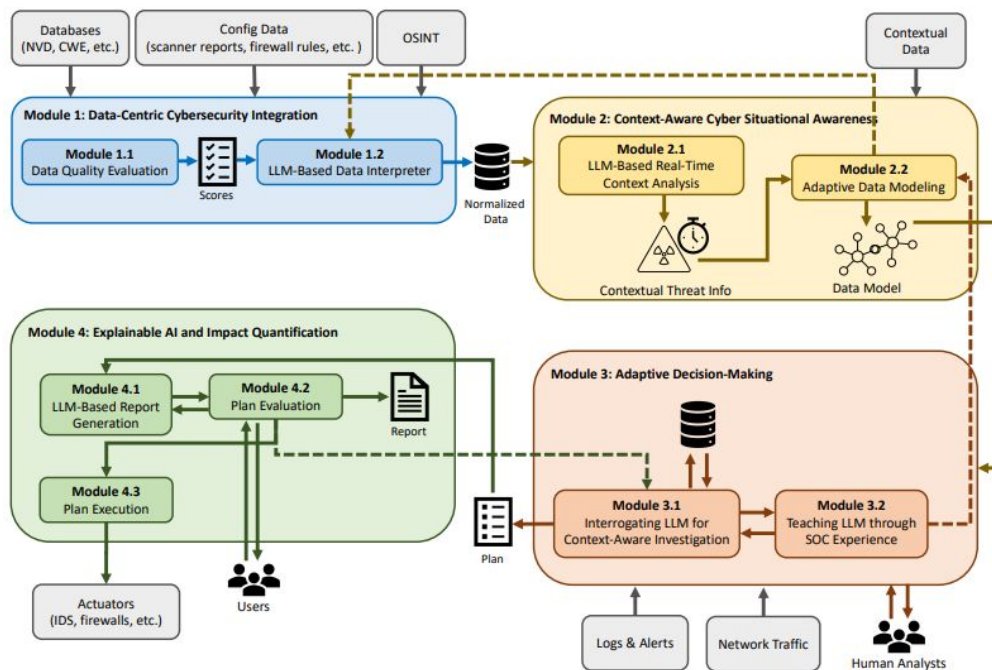
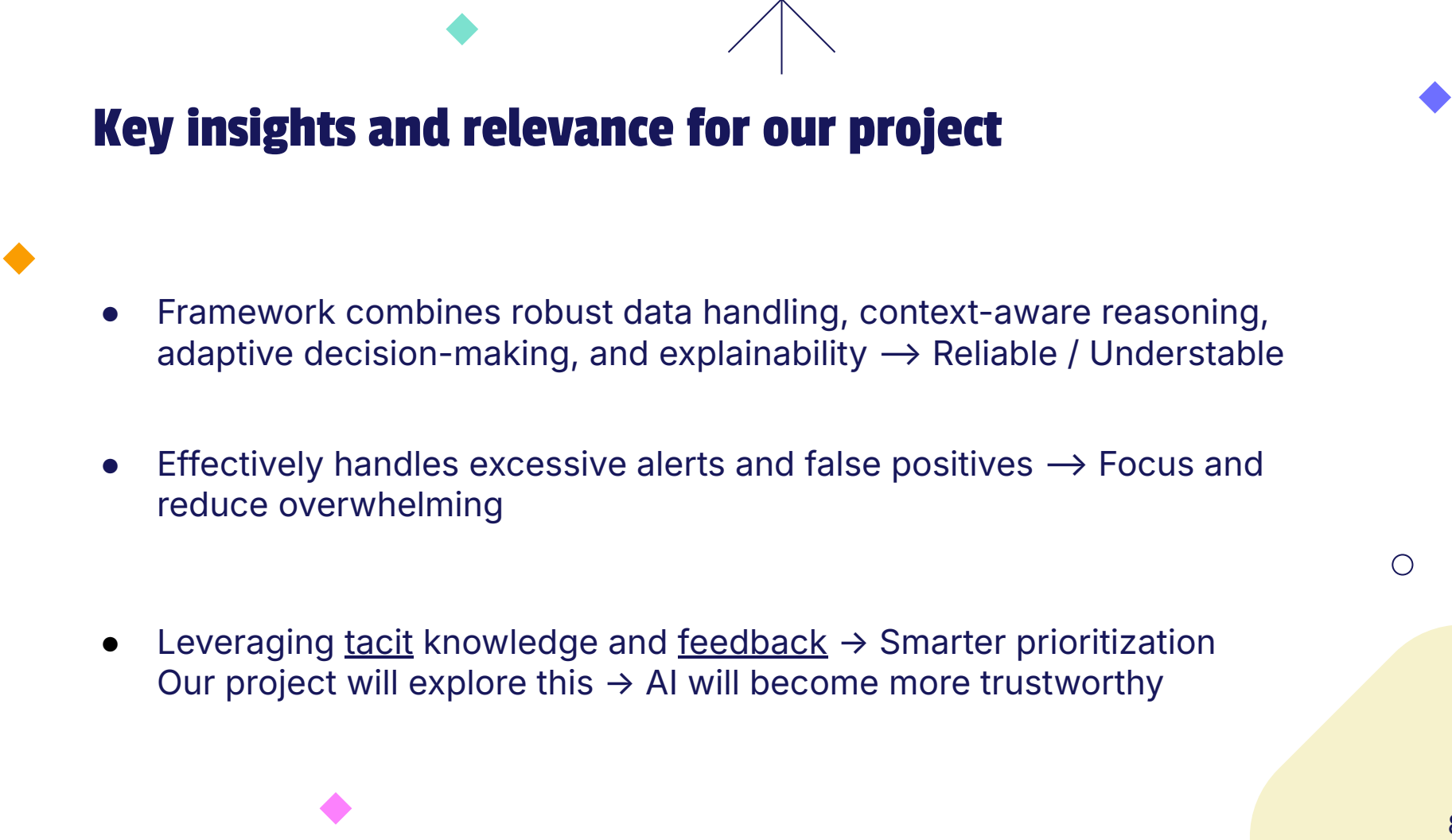


Fig. 3. Overview of the proposed framework.



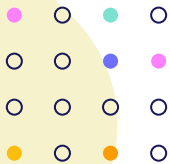
Key insights and relevance for our project

- Framework combines robust data handling, context-aware reasoning, adaptive decision-making, and explainability → Reliable / Understable
- Effectively handles excessive alerts and false positives → Focus and reduce overwhelming
- Leveraging tacit knowledge and feedback → Smarter prioritization
Our project will explore this → AI will become more trustworthy

02.

Human-AI Collaboration in Security Operations Centers with Trusted Autonomy

CyberAlly: A Practical Implementation of Human-AI Teaming in SOCs



A Unified Framework for Human–AI Collaboration in Security Operations Centers with Trusted Autonomy

Ahmad Mohsin

a.mohsin@ecu.edu.au

Centre for Securing Digital Futures, School of Science, Edith Cowan University PerthWestern Australia Australia

Helge Janicke

h.janicke@ecu.edu.au

Centre for Securing Digital Futures, School of Science, Edith Cowan University PerthWestern Australia Australia

Ahmed Ibrahim

ahmed.ibrahim@ecu.edu.au

Centre for Securing Digital Futures, School of Science, Edith Cowan University PerthWestern Australia Australia

Iqbal H. Sarker

i.sarker@ecu.edu.au

Centre for Securing Digital Futures, School of Science, Edith Cowan University PerthWestern Australia Australia

Seyit Camtepe

seyit.camtepe@data61.csiro.au

CSIRO's Data61 SydneyNew South Wales Australia

CyberAlly: Leveraging LLMs and Knowledge Graphs to Empower Cyber Defenders

Minjune Kim

CSIRO's Data61 SydneyNSW Australia
minjune.kim@data61.csiro.au

Jeff Wang

CSIRO's Data61 SydneyNSW Australia
jeff.wang@data61.csiro.au

Problems

- Alert Fatigue
- SOC's are data-rich but context-poor
- Analysts overwhelmed by false positives and duplicates

Réf : [2], [5]

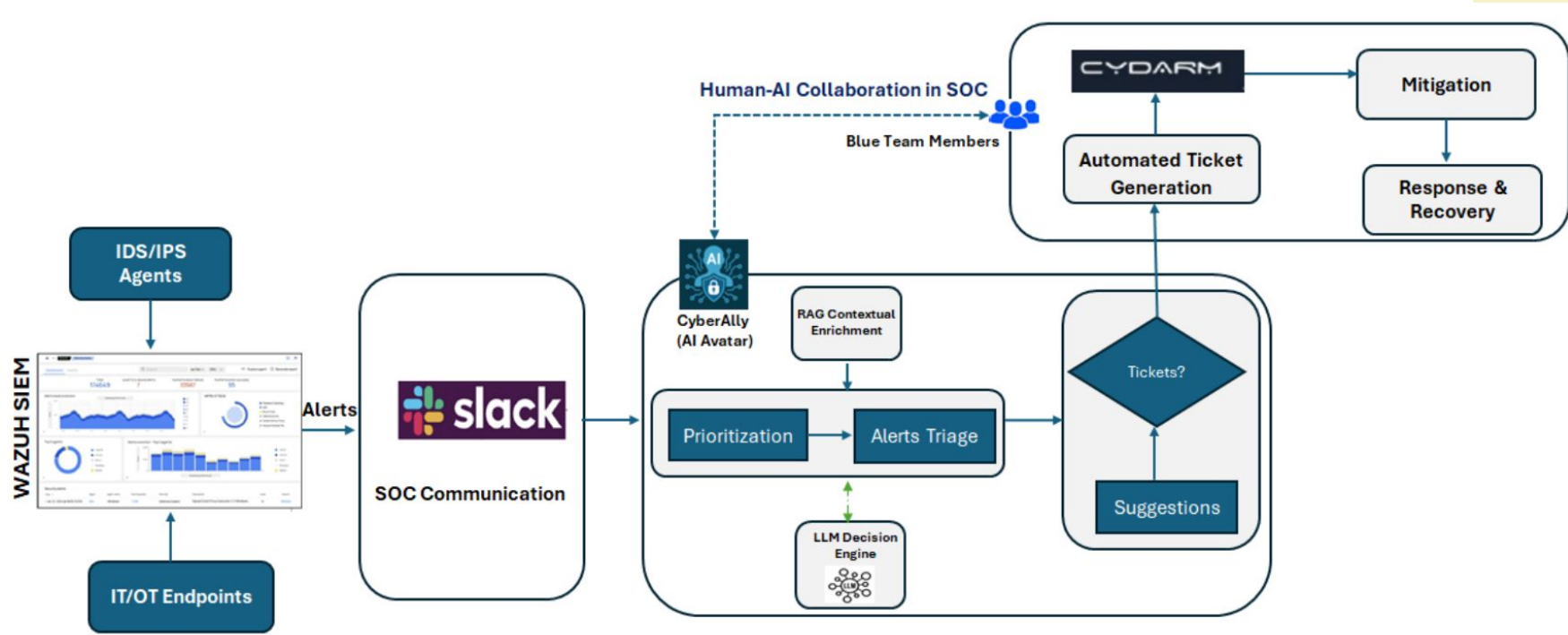


Fig : Human–AI collaboration in a simulated SOC environment integrated into the ACDC Cyber Range. The CyberAlly (Avatar) AI-augmented workflow supports the Blue Team by combining real-time alert triage, LLM-based analysis, and automated ticketing.

Wazuh



All alerts



Blue Team



High severity
of alerts

Binary Classification
(Benign or Suspicious)

Filtering
& Memorization

Filtered alerts

Static Knowledge Graph
and
Dynamic Knowledge Graph

RAG

Prompts
with KGs

LLM

Ticket
creation



Database

cydarm

CyberAlly

Fig : CyberAlly Workflow: The system automatically analyses a high volume of incoming alert messages for the Wazuh SIEM¹ via Slack, generating intelligent suggestions for the Blue Team based on static and dynamic graph knowledge, and automates case ticket creation in Cydarm

Knowledge Graph-Enhanced Reasoning (KG-RAG)

Static Knowledge Graph

- Historical data from previous Red vs. Blue exercises
- MITRE ATT&CK frameworks and patterns
- ...

Dynamic Knowledge Graph

- Current exercise events and alerts
- Real-time Blue Team actions and tickets
- ...

KG-RAG Workflow

- Similarity search in both static and dynamic
- Context enrichment with relevant historical and real-time data
- LLM prompting with enriched context (GPT-4o + LlamaIndex)
- Actionable output with explanations

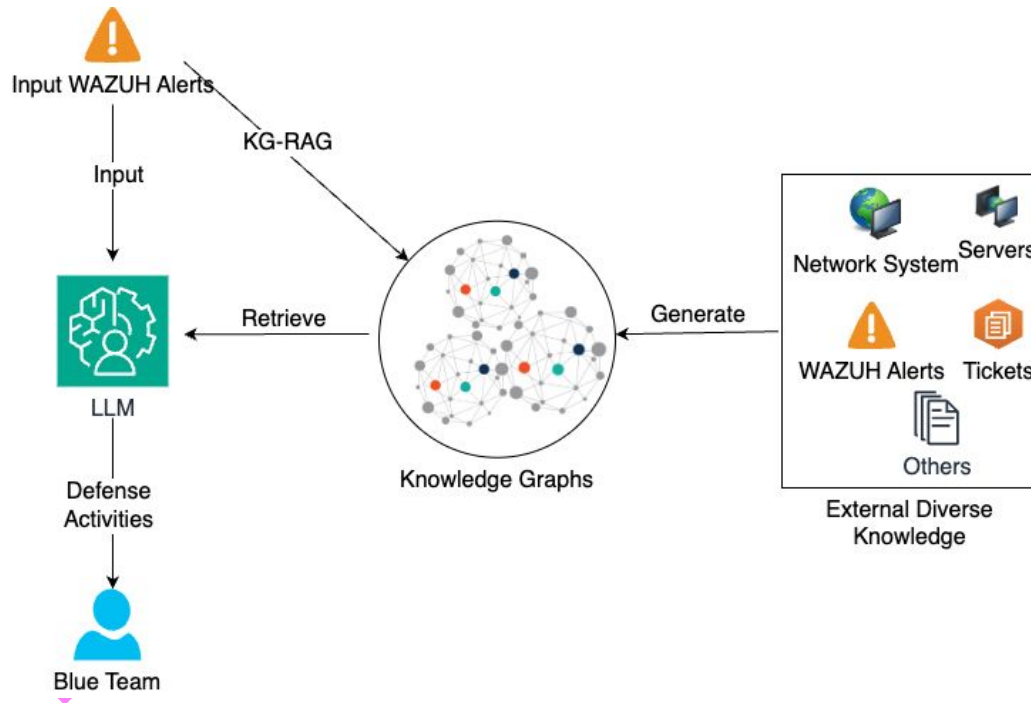


Figure 2: LLM with KG-RAG
Knowledge Graphs capture the relationships between past and present vents and enhance contextual understanding.

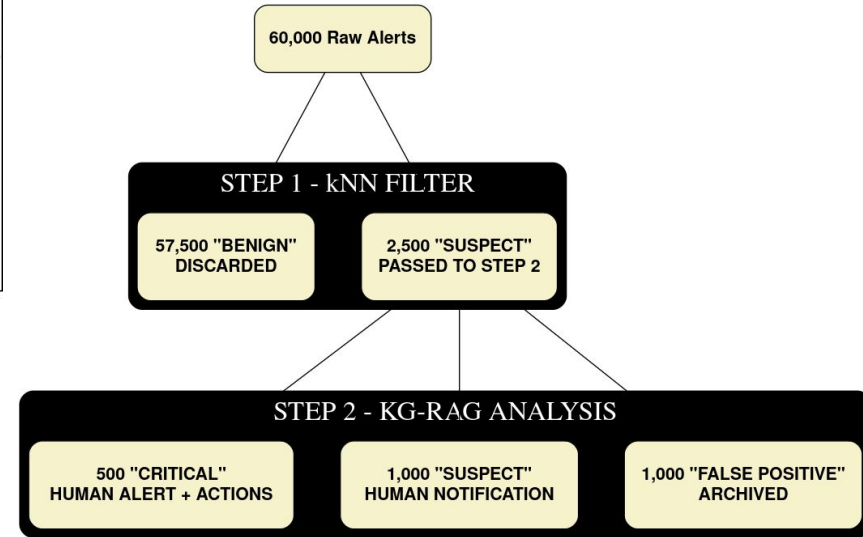
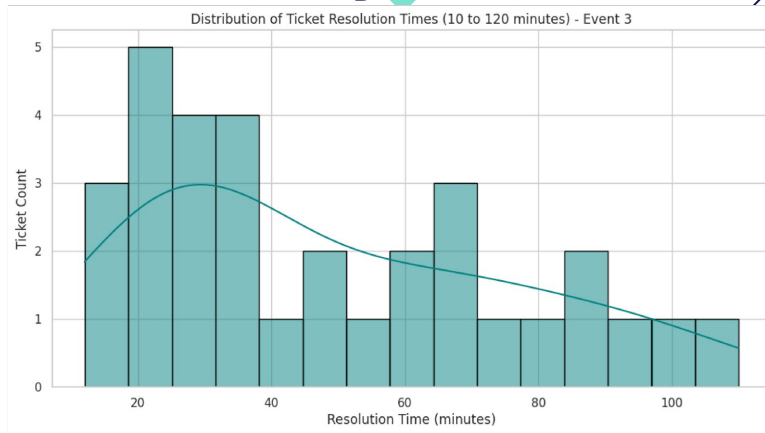
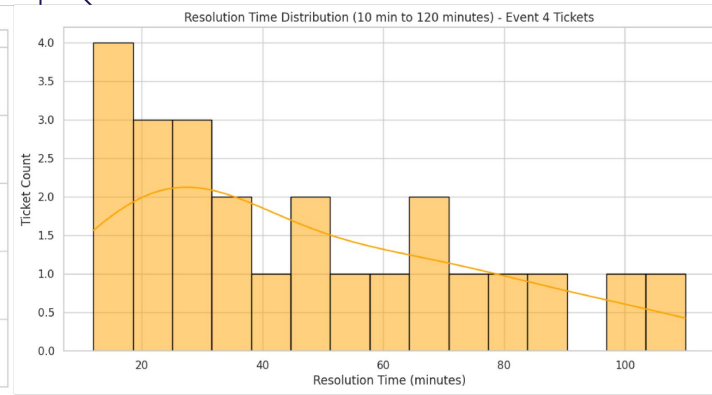


Figure 3: Wargame Alert Triage and Analysis
Workflow - From 60,000 Raw Alerts to Actionable Intelligence

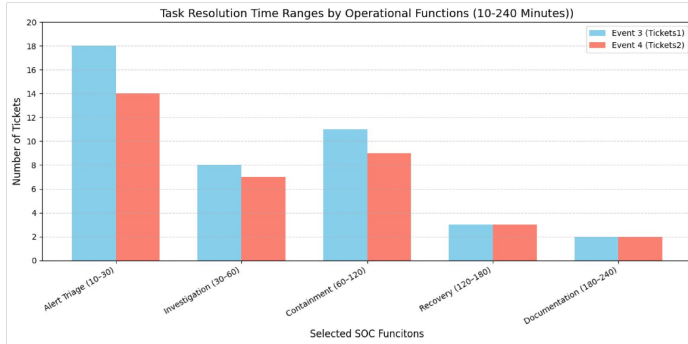
Performance Analysis of Human-AI Collaboration in SOC Tasks



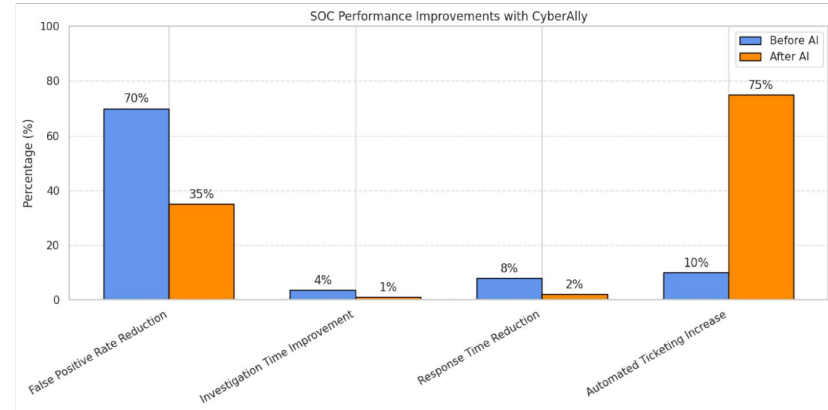
(a) Event 3: Resolution Times



(b) Event 4: Resolution Times



(c) Task Resolution Ranges by SOC Function

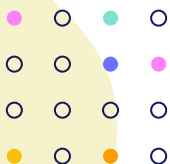


(d) SOC Metrics with AI Avater (CyberAllly) transition

03.

EPSS v3: Predict Real-World Exploits

- CVE = Common Vulnerabilities and Exposures
- CVSS = Common Vulnerability Scoring System
- EPSS = Exploit Prediction Scoring System
 - Range(0-1) → 0.87 High ↑, 0.12 Low ↓
 - EPSS uses an AI/ML model (XGBoost)
 - predicts exploitation in the next 30 days
 - AUC = 0.779 (↑ 82% vs EPSS v2)



Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights

Jay Jacobs
Cyentia Institute
jay@cyentia.com

Sasha Romanosky
RAND Corporation
sromanos@rand.org

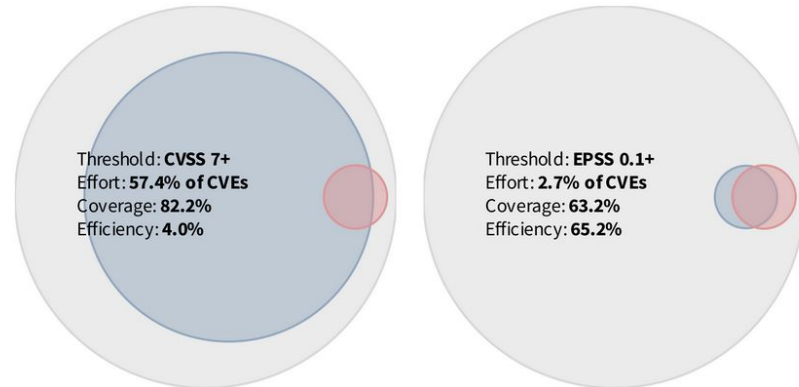
Octavian Suci
University of Maryland
osuci@umd.edu

Ben Edwards
Cyentia Institute
ben@cyentia.com

Armin Sarabi
University of Michigan
arsarabi@umich.edu

The Problem

- 25K+ new vulnerabilities every year
- CVSS score $\neq$ real-world exploitation
- SOC teams suffer from **false urgency**

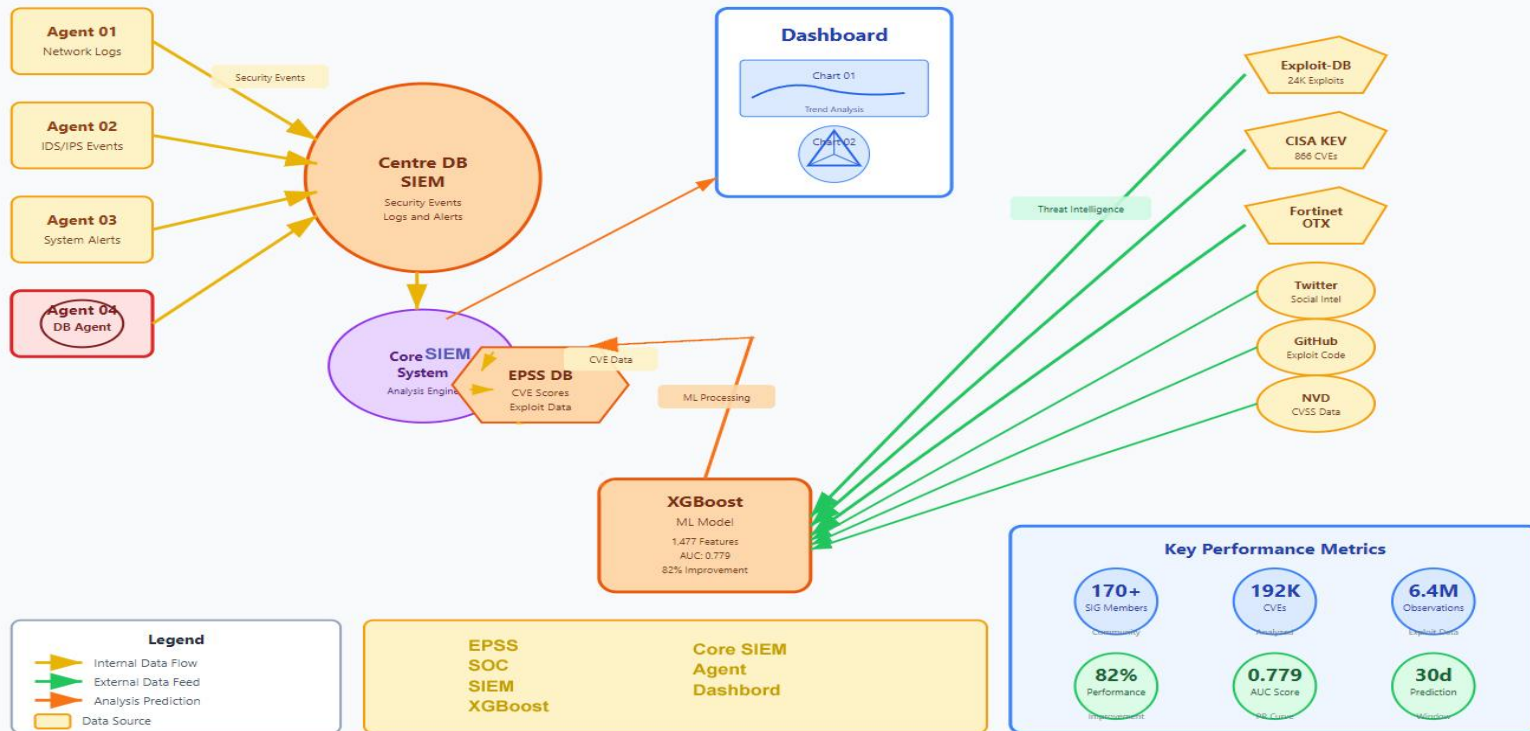


Réf : [4]

How EPSS Works & Application in Our SOC Assistant

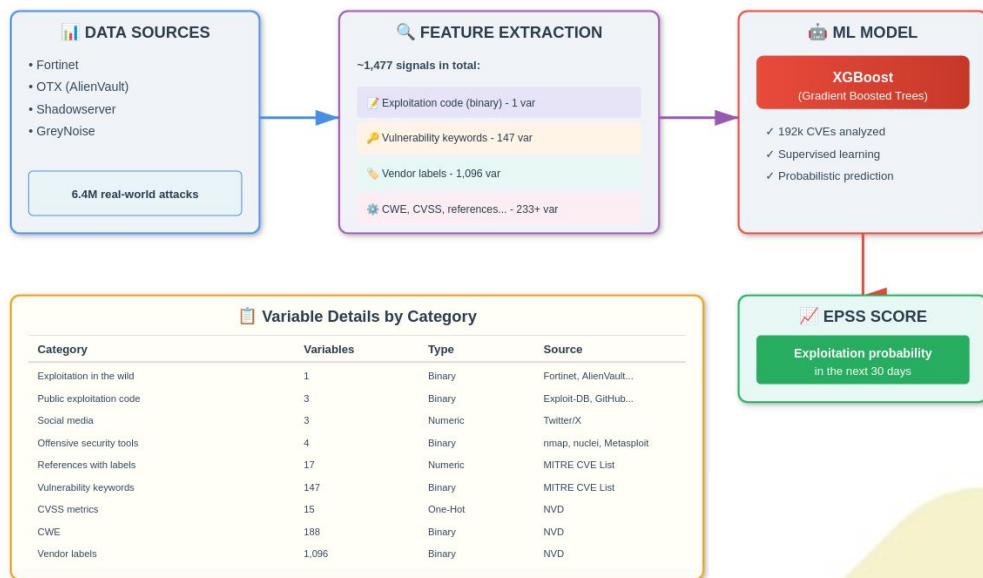
SOC Virtual Assistant - EPSS Integration Architecture

Data-Driven Exploit Predictions with Community-Driven Insights



EPSS v3 MODEL OVERVIEW : More detail

- Data sources: Fortinet, OTX, Shadowserver, GreyNoise...
- Scale: 192k CVEs, 6.4M attack records
- Features: ~1,477 signals (exploit code, keywords, vendor, age...)
- Features → XGBoost(ML) (gradient-boosted trees)
- Daily CSV (~00:00 UTC): cve, epss, percentile, date

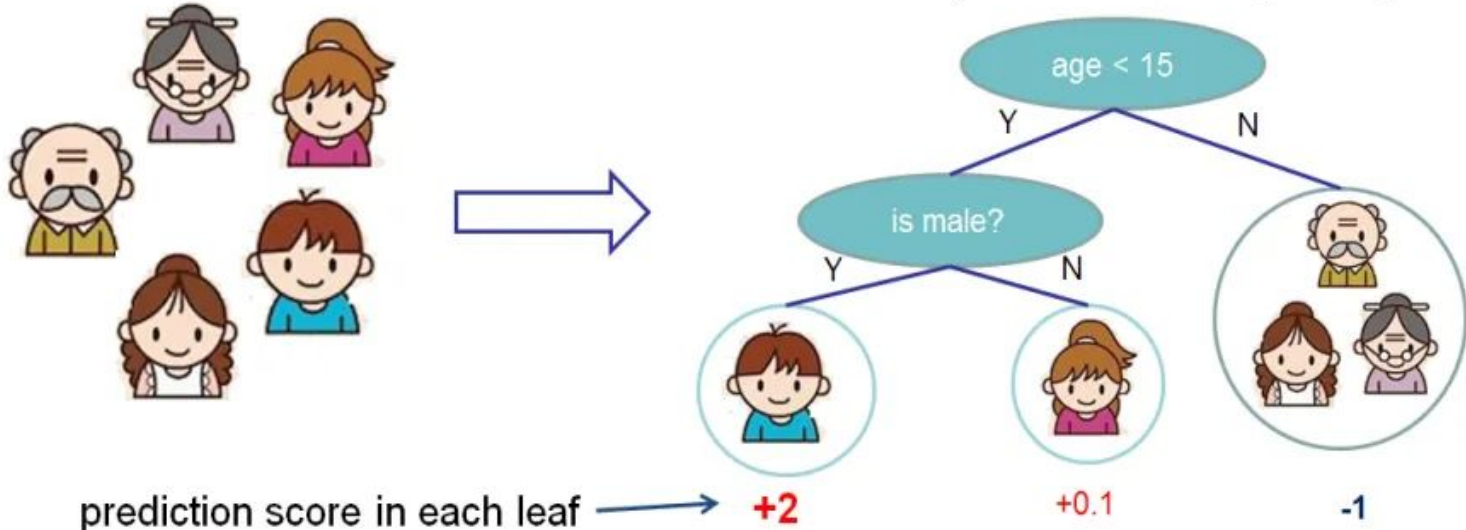


Total: ~1,477 combined signals to predict exploitation risk

XGBoost: gradient-boosted trees

Input: age, gender, occupation, ...

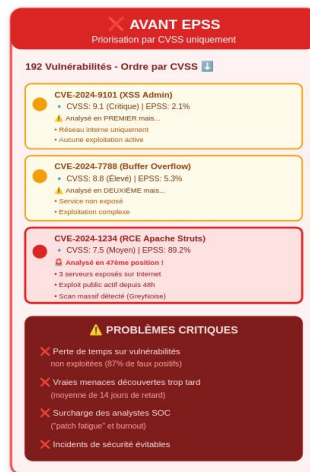
Does the person like computer games



Application in Our SOC Assistant

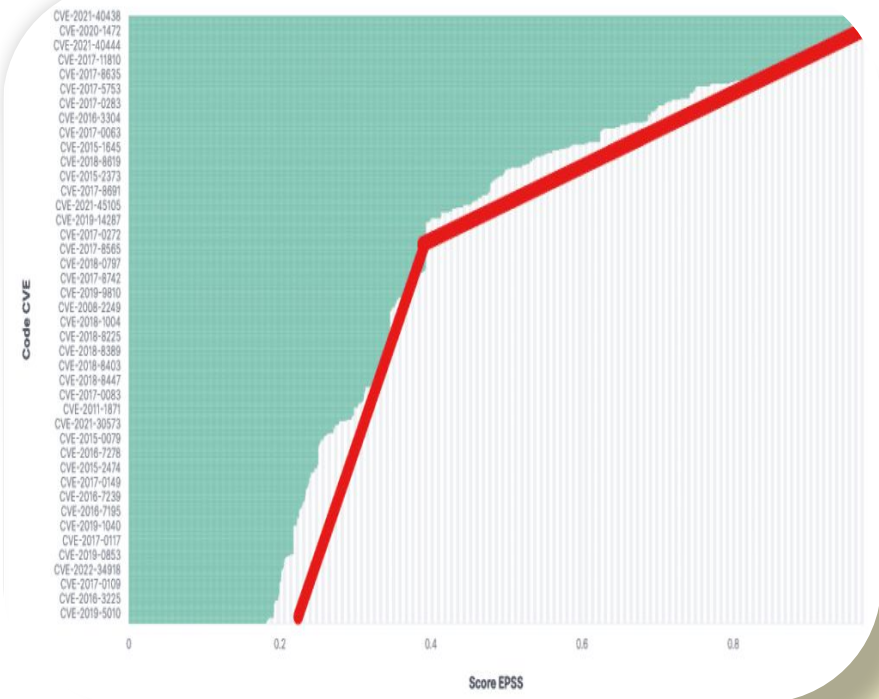
- Integrate EPSS scores in SOC Assistant dashboard
- Highlight high-probability exploits
- Combine with CVSS + context (exposure, active alerts)
- Reduce false alerts and "patch fatigue"

Impact d'EPSS sur la Priorisation des Vulnérabilités



RESULTS AND KEY INSIGHTS

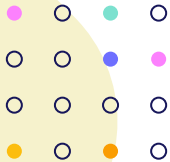
- AUC = 0.779 (↑ 82% vs EPSS v2)
- Top features:
 - ◆ Number of CVE references
 - ◆ "Remote attacker" / "Code execution" keywords
 - ◆ Presence in Exploit-DB or CISA KEV
 - ◆ Vulnerability age
 - ◆ Vendor (Microsoft, Adobe, Google)
- Efficiency: 8× fewer patches for same coverage



04.

Vulnerability Management Chaining

Enhancing Cybersecurity Risk
Prioritization



Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization

Naoyuki Shimizu & Masaki Hashimoto
Faculty of Engineering and Design Kagawa University, Japan

Réf : [4]

Context reminder

- Huge number of CVEs published → overwhelm security teams
- Most vulnerabilities are never exploited in the wild
- Fixing everything wastes time and resources
- Need: prioritize vulnerabilities that are actually risky
- using only one method (CVSS or EPSS or KEV) is not enough

○ Traditional methods

CVSS (severity scores): Mark too many vulnerabilities as “high risk” even if they are never exploited.

EPSS (exploit prediction): miss new or targeted attacks.

KEV (Known Exploited Vulnerabilities): Lists vulnerabilities that are confirmed to be actively exploited, but only after attacks are already happening.



framework Vulnerability Management Chaining :

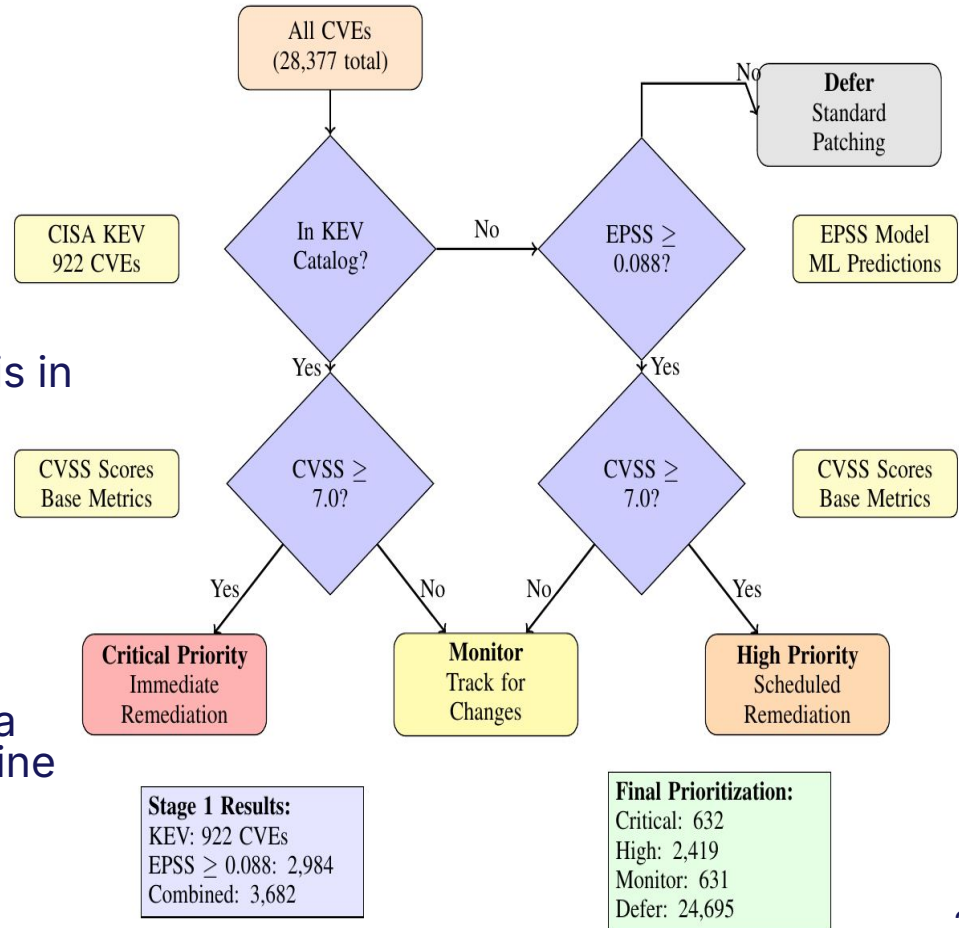
- **Threat likelihood**

1- First check if the vulnerability is in KEV (confirmed exploited).

2- If not, check whether its EPSS score is ≥ 0.088 (likely to be exploited soon).

- **Impact severity**

If the vulnerability is considered a threat, use $CVSS \geq 7.0$ to determine whether it should be treated as high-impact or lower-impact.



Category Meaning Action



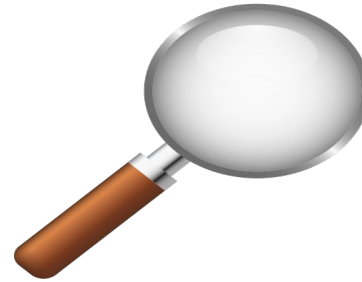
Critical

$KEV + CVSS \geq 7.0$
immediate
remediation



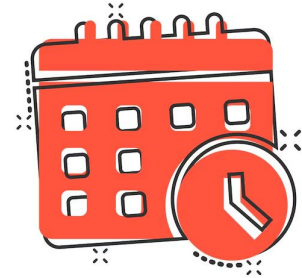
High

$EPSS + CVSS \geq 7.0$
scheduled remediation



Monitor

$KEV \text{ OR } EPSS$
 $+ CVSS < 7.0$
track for changes



Defer

No evidence of
exploitation
Patch during regular
cycles

Before vs After: Vulnerability Management Chaining Impact

Traditional CVSS Only

~16,000

Urgent Vulnerabilities
to Review

95% Reduction

With VMC Framework

~850

Urgent Vulnerabilities
to Review

Key Performance Metrics

18×

More Efficient
compared to
CVSS alone

~85%

Coverage Maintained
Still catches almost
all real threats

+48

Extra Vulnerabilities
Found by combining
KEV + EPSS

Balanced

Fewer false alarms
Fewer misses

What This Means for SOC Teams

✓ Less Time Wasted

Focus only on vulnerabilities
that are actually dangerous
and likely to be exploited

✓ Better Detection

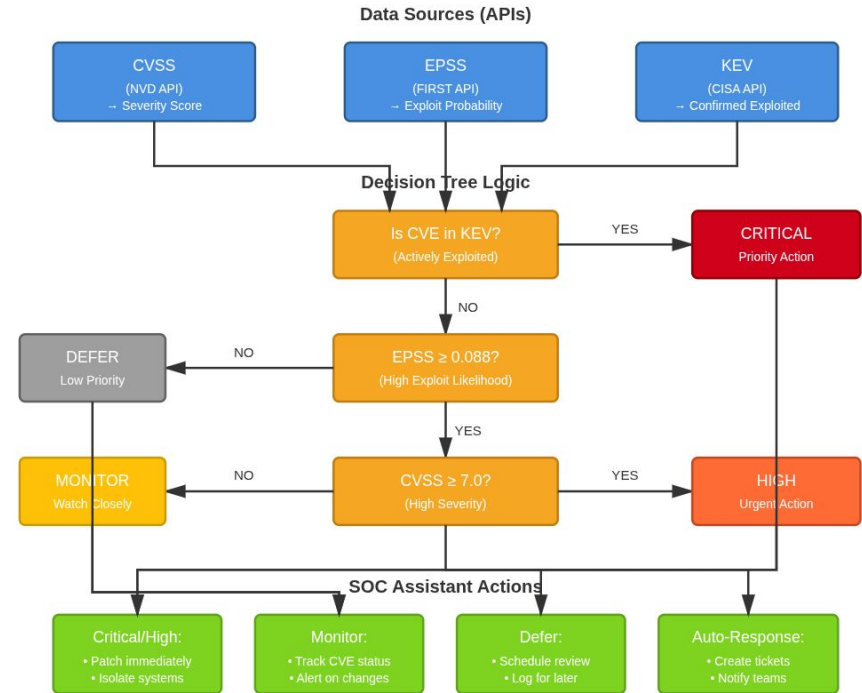
Combining multiple sources
catches threats that single
systems would miss

✓ Smart Prioritization

Real-world exploit data
helps teams work on what
matters most first

Application in Our SOC Assistant

- Use APIs from:
NVD API - FIRST API - CISA API
- exploited Apply the decision tree
- The Assistant classifies the vulnerability
- Then it recommends or triggers the right action



Next Steps for Implementation

- Deliver a CyberAlly-inspired assistant focused on intelligent vulnerability management
- Develop prioritization scoring algorithm
- Scenario: Compromised Account | The SOC assistant must help the analyst manage this alert

References

- [1] M. Albanese, X. Ou, K. Lybarger, D. Lende, and D. Goldgof, "Towards AI-Driven Human-Machine Co-Teaming for Adaptive and Agile Cyber Security Operation Centers," arXiv preprint arXiv:2505.06394, 2025. [Online]. Available: <https://arxiv.org/abs/2505.06394>
- [2] A. Mohsin, H. Janicke, A. Ibrahim, I. H. Sarker, and S. Camtepe, "A Unified Framework for Human AI Collaboration in Security Operations Centers with Trusted Autonomy," arXiv preprint arXiv:2505.23397, 2025. [Online]. Available: <https://arxiv.org/abs/2505.23397>
- [3] N. Shimizu and M. Hashimoto, "Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization," arXiv preprint arXiv:2506.01220, 2025. [Online]. Available: <https://arxiv.org/abs/2506.01220>
- [4] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights," arXiv preprint arXiv:2302.14172, 2023. [Online]. Available: <https://arxiv.org/abs/2302.14172>
- [5] Minjune Kim, Jeff Wang, Kristen Moore, Diksha Goel, Derui Wang, Ahmad Mohsin, Ahmed Ibrahim, Robin Doss, Seyit Camtepe, and Helge Janicke. 2025. CyberAlly: Leveraging LLMs and Knowledge Graphs to Empower Cyber Defenders. [Online]. Available : <https://arxiv.org/abs/2504.07457>